ISO/IEC 27001 Risk Assessment Report

Organization: Endpoint Technologies PLC
Prepared By: Asfi Ahmed
Role: Cybersecurity Analyst (Fresher)
Date: 8th April, 2026

1. Executive Summary

This report presents a comprehensive information security risk assessment conducted for Endpoint Technologies PLC in alignment with ISO/IEC 27001.

The objective of this assessment is to identify, evaluate, and treat risks associated with the organization's internal network infrastructure, systems, and information assets. The assessment focuses on ensuring the **confidentiality, integrity, and availability (CIA)** of critical business data.

A total of **50+ risks** were identified across multiple domains, including network devices, servers, endpoints, applications, and data repositories. These risks were evaluated using a structured **Likelihood–Impact scoring model**, and appropriate mitigation strategies were recommended using ISO Annex A controls.

Key findings indicate that the organization faces significant risks in:

- Network architecture (lack of segmentation)
- Access control mechanisms
- Web application security
- Data protection and encryption
- Human-related threats (phishing and credential compromise)

The implementation of recommended controls will significantly enhance the organization's security posture and reduce overall risk exposure.

2. Company Overview

Endpoint Technologies PLC is a mid-sized software development and IT services organization based in Dhaka, Bangladesh. The company provides:

- Web and mobile application development

- API-based enterprise solutions
- Internal SaaS platforms

Organizational Size:

- Approximately 50–100 employees

Information Assets:

The organization processes and stores:

- Client project data
- Source code repositories
- Employee credentials
- Internal communications
- Financial records

Security Context:

Due to the handling of sensitive client data and the presence of publicly exposed systems (e.g., web server), the organization is exposed to both internal and external cyber threats. Therefore, a structured risk assessment is necessary to identify vulnerabilities and implement appropriate controls.

3. Scope of ISMS

Scope Definition:

The scope of the Information Security Management System (ISMS) includes all internal IT infrastructure that supports business operations within the organization.

Included Assets:

- Network devices (routers, switches, wireless access points)
- Servers (web server, database server)
- Employee workstations
- Internal communication systems
- Data storage systems

Excluded Assets:

- Third-party cloud services
- External client environments

- Personal devices not connected to corporate network

Scope Boundary:

The ISMS applies to systems physically located within the organization's premises and logically connected to the internal network.

4. Methodology

4.1 Risk Identification

Risks were identified by analyzing:

- Organizational assets
- Potential threats
- Existing vulnerabilities

This process covered:

- Network infrastructure
- Servers and applications
- Endpoints
- Data assets

4.2 Risk Analysis

Each risk was evaluated using a quantitative scoring model:

Risk Score = Likelihood × Impact

Likelihood Scale:

1 – Rare
2 – Unlikely
3 – Possible
4 – Likely
5 – Almost Certain

Impact Scale:

1 – Negligible
2 – Minor
3 – Moderate

4 – Major
5 – Critical

4.3 Risk Evaluation

Based on calculated scores, risks were categorized:

- **Low Risk:** 1–5
- **Medium Risk:** 6–12
- **High Risk:** 15–25

4.4 Risk Treatment

Each identified risk was assigned a treatment strategy:

- **Mitigate** – Apply controls to reduce risk
- **Accept** – Accept risk if within tolerance
- **Transfer** – Shift risk (e.g., outsourcing, insurance)
- **Avoid** – Eliminate the activity causing the risk

5. Asset Overview

A total of **17 key assets** were identified and categorized into:

- Network Devices
- Servers
- Endpoints
- Data Assets
- Applications
- Storage Systems

Critical Assets:

- Web Server (public-facing)
- Database Server
- Client Project Data
- Employee Credentials Database

These assets were prioritized due to their high business impact in case of compromise.

6. Risk Summary

A total of **50+ risks** were identified across all asset categories.

Risk Distribution:

- **High Risks:** Significant portion (critical concern)
- **Medium Risks:** Moderate exposure
- **Low Risks:** Minimal impact

Key Risk Areas Identified:

🔹 Network Risks

- Unauthorized access to network devices
- Lack of VLAN segmentation enabling lateral movement
- Misconfigured firewall and ACL rules

🔹 Server Risks

- Web application vulnerabilities (SQL Injection, XSS)
- Outdated software and patch management issues
- Weak access control on database systems

🔹 Data Risks

- Lack of encryption at rest
- Weak credential management
- Exposure of sensitive data

🔹 Endpoint Risks

- Malware infections
- Phishing and social engineering
- Lack of endpoint protection

🔹 Business Continuity Risks

- Single ISP dependency
- Lack of backup isolation

7. Risk Treatment Summary

High and medium risks were prioritized for mitigation using ISO Annex A controls.

Key Security Improvements Recommended:

🔹 Access Control

- Implementation of Multi-Factor Authentication (MFA)
- Role-Based Access Control (RBAC)
- Strong password policies

🔹 Network Security

- VLAN segmentation to prevent lateral movement
- Secure configuration of switches and routers
- Firewall rule hardening

🔹 Application Security

- Input validation and output encoding
- Deployment of Web Application Firewall (WAF)
- Regular patch management

🔹 Data Protection

- Encryption at rest and in transit
- Data Loss Prevention (DLP) strategies

🔹 Backup & Recovery

- Air-gapped backups
- Regular backup testing

🔹 Email Security

- Implementation of SPF, DKIM, and DMARC
- Email filtering and monitoring

8. Residual Risk Overview

After implementing the recommended controls, most risks are reduced to **low or medium levels**.

Remaining Residual Risks:

- DDoS attacks (cannot be fully eliminated)
- ISP dependency risks
- Human-related risks such as phishing

These risks require continuous monitoring and periodic reassessment.

9. Conclusion

The risk assessment highlights that Endpoint Technologies PLC is exposed to multiple critical security risks, particularly in network architecture, access control, and application security.

By implementing the recommended mitigation strategies aligned with ISO/IEC 27001, the organization can significantly strengthen its security posture and reduce overall risk exposure.

Continuous monitoring, employee awareness, and periodic reassessment are essential to maintaining long-term security effectiveness.

10. Appendix (Optional Section)

- Asset Register

Asset ID	Asset Name	Asset Type	Owner	Value	Location
A1	Cisco ISR 1100 Edge Router	Network Device	IT Administrator	High	Server Room
A4	TP-Link Archer C6 Wireless Access Point	Network Device	IT Administrator	Medium	Office Ceiling
A7	Dell PowerEdge R650xs Internal Server	Server	IT Team	Critical	Server Room
A9	Network Configuration Files	Data	IT Administrator	High	Server Room
A11	Source Code Repository (Git)	Data	Development Team	Critical	Server Room
A13	Financial Records System	Application	Finance Department	High	Server Room
A15	Firewall Rules & ACL Configurations	Configuration	IT Administrator	High	Network Devices

- Risk Register

Risk ID	Asset	Threat	Vulnerability	Likelihood	Impact	Score	Level
R01	Cisco ISR 1100 Edge Router	1. DDoS Attack	1. Unpatched firmware (CVEs)	4	4	16	High
R10	TP-Link Archer C6 Wireless Access Point	1. WPA2 Krack/Password Cracking	1. Consumer-grade hardware (limited security updates)	5	3	15	High
R19	Dell PowerEdge R650xs Internal Server	1. iDRAC/IPMI Remote Hijack	1. Outdated BIOS/UEFI firmware	2	5	10	Medium
R25	Network Configuration Files	1. Unauthorized discovery of network map	1. Stored in unencrypted shared drives	3	4	12	Medium
R31	Source Code Repository (Git)	1. Industrial Espionage	1. Lack of Multi-Factor Auth (MFA) on Git	3	5	15	High
R37	Financial Records System	1. Business Email Compromise (BEC)	1. Lack of "Dual-Control" (Four Eyes) policy	4	5	20	High
R43	Firewall Rules & ACL Configurations	1. Policy Bypass (Shadow IT)	1. "Any-Any" rules left for testing	3	4	12	Medium

- Risk Treatment Plan

Risk ID	Risk Description	Treatment	Control (ISO Annex A)	Action Plan	Owner	Timeline	Residual Risk	Status
R01	Unauthorized access to router due to weak credentials	Mitigate	A.9 Access Control	Enforce strong password policy and implement MFA for admin access	IT Administrator	2 weeks	Low	Planned
R04	MAC flooding attack on switch	Mitigate	A.13 Network Security	Enable port security and disable unused switch ports	Network Engineer	2 weeks	Medium	Planned
R13	SQL Injection / XSS on web server	Mitigate	A.14 Secure Development	Implement input validation, output encoding, and deploy WAF	DevOps Team	2 weeks	Low	Planned
R22	Phishing attack on employees	Mitigate	A.7 Human Resource Security	Conduct security awareness training and phishing simulations	HR / IT	3 weeks	Medium	Planned
R49	ISP outage due to single provider	Transfer	A.17 Business Continuity	Implement secondary ISP for redundancy (failover setup)	Management	1 month	Medium	Planned
R52	Lateral movement due to flat network	Mitigate	A.13 Network Security	Implement VLAN segmentation and internal firewall rules	Network Engineer	3 weeks	Low	Planned